

**SIMATS ENGINEERING**  
**ASSESSMENT TOOL 3 – CASE STUDY**

**COURSE CODE: ITA14**

**COURSE NAME: Ethical Hacking**

**COURSE OUTCOME COVERED**

*CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)*

Assessment Tool Weightage: 35%

**QUESTIONS: 5**

**Total Marks:100**

- 
1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.
  2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and

SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.
4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.
5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

**Code of Conduct:**

*I KALPANA J(192521038) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

*Signature of the student:*  
**KALPANA J**

**RUBRICS FOR CALCULATION**

| <b>Criteria</b>         | <b>Weightage</b> | <b>Level 4 – Exemplary</b>                                       | <b>Level 3 – Proficient</b>                    | <b>Level 2 – Developing</b>             | <b>Level 1 – Beginning</b>                           |
|-------------------------|------------------|------------------------------------------------------------------|------------------------------------------------|-----------------------------------------|------------------------------------------------------|
| Understanding of Case   | 25               | Thorough understanding; clearly identifies all key issues        | Good understanding with most issues identified | Basic understanding; some issues missed | Poor understanding; problem not identified correctly |
| Application of Concepts | 25               | Effectively applies relevant concepts to analyze the case deeply | Applies appropriate concepts with minor gaps   | Limited application of concepts         | Fails to apply relevant concepts                     |
| Analysis                | 20               | In-depth analysis with strong reasoning and insights             | Good analysis with logical reasoning           | Basic analysis with limited depth       | Weak or no analysis; lacks reasoning                 |
| Solution Design         | 20               | Innovative, feasible solutions with strong justification         | Logical solutions with adequate justification  | Basic solutions with weak justification | Incorrect or no solution provided                    |
| Clarity                 | 10               | Clear, well-structured, and easy to understand                   | Organized and understandable presentation      | Limited clarity and structure           | Poor clarity difficult to understand                 |

# **1. VULNERABILITY ASSESSMENT REPORT**

## **1. Title**

**Security Assessment of an E-Commerce Web Application Hosted on Apache/Linux**

## **2. Objective**

The objective of this assessment is to identify vulnerabilities in an Apache-based e-commerce application, analyze possible attack vectors, evaluate outdated software and input-validation weaknesses, and recommend a layered security architecture.

## **3. Scenario**

A mid-sized e-commerce company hosts its web application on an Apache server running on Linux. Customers reported unauthorized transactions and abnormal account activities. Investigation identified suspicious HTTP requests, attempts to access hidden directories, malicious scripts submitted through input fields, outdated server software, and the absence of a Web Application Firewall.

The main potential attack vectors are:

- Directory and file enumeration
- Outdated Apache/software vulnerabilities
- Cross-Site Scripting (XSS)
- Injection vulnerabilities
- Weak authentication/session management
- Insecure server configuration
- Missing WAF and monitoring

## **4. Tools Used**

- Kali Linux
- Nmap
- Nikto
- Gobuster

- Burp Suite
- WhatWeb
- cURL • Wireshark

## 5. Methodology

The assessment follows:

Reconnaissance



Scanning



Web Enumeration



Vulnerability Identification



Controlled Validation



Risk Assessment



Mitigation

## 6. Reconnaissance

First identify the authorized lab target:

ip addr

Perform basic host discovery:

```
nmap -sn <LAB-NETWORK>/24
```

Identify open ports:

```
nmap -sV <LAB-IP>
```

A more detailed authorized scan can be performed with:

```
nmap -sC -sV <LAB-IP>
```

## 7. Web Server Enumeration

Identify technologies:

whatweb http://<LAB-IP>

Check HTTP headers: curl

-I http://<LAB-IP>

Perform a web-server

security assessment:

nikto -h http://<LAB-IP>

Nikto can identify potentially dangerous configurations, outdated components, and common web-server weaknesses.

## 8. Directory Enumeration

Use Gobuster against the authorized lab application: gobuster dir -u

http://<LAB-IP> -w /usr/share/wordlists/dirb/common.txt

Potential findings may include:

/admin  
/login  
/uploads  
/backup  
/test

These findings must be verified manually because an enumerated directory is not automatically a vulnerability.

## 9. Web Application Testing

Start Burp Suite:

burpsuite

Configure the browser to use the Burp proxy and access the authorized application.

Test input fields for:

- Input validation
- XSS
- Injection
- Authentication issues
- Session management
- Access-control weaknesses

For a controlled XSS test, use a harmless proof-of-concept such as:

```
<script>alert('XSS-Test')</script>
```

Only use this against the intentionally vulnerable laboratory application.

## 10. Outdated Software Assessment

Identify server versions:

```
nmap -sV -p 80,443 <LAB-IP>
```

The discovered version should then be compared against the vendor's official security advisories and CVE databases.

An outdated version does not automatically mean exploitation is possible; the exact version, configuration, modules, and applicable patches must be verified.

## 11. Attack Vectors

### A. Directory Enumeration

Attackers may discover hidden administrative or backup resources.

### B. XSS

Improper input validation can allow malicious scripts to execute in users' browsers.

### C. Outdated Apache

Known vulnerabilities in obsolete software may increase the attack surface.

## D. Injection

Improperly handled input can allow attacker-controlled data to influence application processing.

## E. Weak Authentication

Weak account controls can facilitate unauthorized access.

## 12. CIA Impact

| Security Property | Impact                                  |
|-------------------|-----------------------------------------|
| Confidentiality   | Customer information may be exposed     |
| Integrity         | Transactions/accounts could be modified |
| Availability      | Application could become unavailable    |

## 13. Risk Assessment

| Vulnerability         | Severity            |
|-----------------------|---------------------|
| Outdated server       | High                |
| XSS                   | High                |
| Directory exposure    | Medium/High         |
| Input validation      | High                |
| Missing WAF           | Medium/High         |
| Weak session controls | Critical if present |

## 14. Recommendations

### Server Hardening

- Update Apache and Linux packages.
- Remove unnecessary modules.
- Disable directory listing.
- Remove test and backup files.
- Use secure file permissions.
- Disable unnecessary services.
- Configure secure HTTP headers.

## Secure Coding

- Validate input using allowlists.
- Encode output based on its context.
- Use parameterized queries.
- Implement CSRF protection.
- Secure authentication and sessions.

## Network Protection

- Deploy a WAF.
- Use IDS/IPS.
- Segment web, database, and management networks.
- Restrict database access.
- Centralize logs. **Monitoring**

Monitor:

- Authentication failures
- Suspicious HTTP requests
- Administrative access
- File changes
- Repeated scanning attempts
- Unusual transactions

## 15. Conclusion

The e-commerce application presents significant risk when outdated software, weak input validation, exposed directories, and insufficient network protection are combined. A layered defense involving secure software development, regular patching, WAF protection, network segmentation, strong authentication, and continuous monitoring can significantly reduce the likelihood and impact of future attacks.

```

(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83906sec preferred_lft 83906sec
    inet6 fd17:625c:f037:2:c895:be2a:58f0:bb0e/64 scope global dynamic noprefixroute
        valid_lft 86246sec preferred_lft 14246sec
    inet6 fe80::66cb:297d:718a:d5c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ nmap <TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ nikto -h http://<TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ gobuster dir -u http://<TARGET-IP> -w /usr/share/wordlists/dirb/common.txt
zsh: no such file or directory: TARGET-IP

(kali@kali)-[~]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
Your JRE appears to be version 21.0.9 from Debian
Burp has not been fully tested on this platform and you may experience problems.
^C

(kali@kali)-[~]
$ curl -I http://<TARGET-IP>
zsh: parse error near `\\n'

```



## 2. SECURITY AUDIT REPORT

### 1. Title

**Assessment of SQL Injection and Cross-Site Scripting Vulnerabilities in a Financial Web Application**

### 2. Objective

The objective is to identify and validate SQL injection and XSS vulnerabilities in an authorized financial web application, evaluate their impact on the CIA triad, and recommend comprehensive security controls.

### 3. Scenario

The financial application allows customers to log in, view account details, and perform transactions. Security testing identified SQL injection and XSS vulnerabilities. Error messages also reveal database information, increasing the amount of information available to attackers.

### 4. Tools Used

- Kali Linux
- Burp Suite
- SQLmap
- Nmap
- cURL
- Browser Developer Tools

### 5. Methodology

Reconnaissance



Application Mapping



Parameter Identification



Manual Testing



Controlled SQL Injection Validation



XSS Validation



Impact Analysis



Mitigation

### 6. Reconnaissance

Identify the authorized server:

```
nmap -sV <LAB-IP>
```

Identify web services:

```
nmap -p 80,443 <LAB-IP>
```

Check headers:

```
curl -I http://<LAB-IP>
```

## 7. Burp Suite Assessment

Start Burp Suite:

```
burpsuite
```

Configure the browser proxy and browse the authorized application.

Burp can be used to inspect:

- Login requests
- GET parameters
- POST parameters
- Cookies
- HTTP headers
- Server responses
- Error messages

## 8. SQL Injection Testing

A suspected parameter should first be tested manually in Burp Repeater using harmless syntax variations.

For example, in an intentionally vulnerable lab:

```
?id=1'
```

Observe whether the application produces an SQL-related error or unusual response.

A logically equivalent test may be performed in the lab:

```
?id=1 AND 1=1
```

and:

```
?id=1 AND 1=2
```

Different responses can indicate possible Boolean-based SQL injection.

## 9. SQLmap Validation

After identifying an authorized vulnerable URL, SQLmap can be used for controlled validation.

Example: `sqlmap -u "http://<LAB-`

`IP>/item?id=1" --batch`

For a lab application where database enumeration is explicitly authorized: `sqlmap`

`-u "http://<LAB-IP>/item?id=1" --dbs --batch`

The objective is to confirm the vulnerability rather than extract real customer information.

## 10. XSS Testing

Identify an input field in the authorized test application.

Use a harmless test payload: `<script>alert('XSS-Test')</script>`

Observe whether the input is:

1. Rejected,
2. Encoded, or
3. Executed by the browser.

Burp Suite can be used to intercept and modify the request.

## 11. Error Message Analysis

Observe whether application errors expose:

- Database names
- Table names
- SQL statements
- File paths
- Framework information
- Stack traces

Detailed database errors should not be shown to ordinary users.

## 12. CIA Impact

### Confidentiality

SQL injection could allow unauthorized access to sensitive financial records.

## Integrity

An attacker may potentially modify application or database information if sufficient privileges are available. **Availability**

Resource-intensive queries or malicious input may affect application availability.

## XSS Impact

XSS can compromise user sessions, manipulate displayed content, and perform actions in a victim's browser depending on application controls.

## 13. Risk Assessment

| Vulnerability             | Severity      |
|---------------------------|---------------|
| SQL Injection             | Critical      |
| Stored XSS                | High/Critical |
| Reflected XSS             | High          |
| Database error disclosure | Medium        |
| Weak session management   | High          |

## 14. Recommendations

### SQL Injection

- Use parameterized queries.
- Use prepared statements.
- Avoid dynamic SQL.
- Apply least-privilege database accounts.
- Validate input.

### XSS

- Context-aware output encoding.
- Input validation.
- Content Security Policy.
- Secure cookies.
- HttpOnly cookies where appropriate.

### Session Security

Use:

Secure  
HttpOnly SameSite

for appropriate session cookies.

Implement:

- Session expiration
- Session regeneration after authentication
- Logout invalidation
- MFA for sensitive operations

## **Error Handling**

Replace detailed database errors with generic messages.

## **15. Conclusion**

SQL injection and XSS represent serious threats to financial applications because they can affect sensitive information, transactions, user accounts, and application integrity. Parameterized queries, output encoding, secure session management, least-privilege database access, CSP, and appropriate monitoring are essential for protecting financial systems.

```
(kali@kali)-[~]
$ nmap -sV <TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ nmap -sV <TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ sqlmap -u "http://<TARGET-IP>/product?id=1" --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey
responsible for any misuse or damage caused by this program

[*] starting @ 23:52:33 /2026-08-21/

[23:52:33] [CRITICAL] host '<TARGET-IP>' does not exist
[23:52:33] [WARNING] your sqlmap version is outdated

[*] ending @ 23:52:33 /2026-08-21/

(kali@kali)-[~]
$ curl -I http://<TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ <script>alert('XSS')</script>
zsh: parse error near `\\n'
```



### 3. WIRELESS SECURITY ASSESSMENT REPORT

#### 1. Title

Assessment of an Evil-Twin Attack Against a Corporate WPA2-PSK Wireless Network

#### 2. Objective

To analyze how a rogue access point can imitate a legitimate wireless network, identify the weaknesses that enable the attack, and recommend stronger wireless authentication, monitoring, and user-awareness controls.

### 3. Scenario

Employees reported unusual login prompts and poor wireless performance. Investigation identified a rogue access point using the same SSID as the organization's legitimate wireless network.

The attacker attempted to attract users to the rogue AP and potentially intercept or manipulate their traffic.

### 4. Tools Used

- Kali Linux
- Aircrack-ng suite
- Airodump-ng
- Wireshark
- Kismet
- Nmap

### 5. Attack Chain

Legitimate Wi-Fi



Attacker observes SSID



Rogue AP identified



User connects



Traffic may be exposed/manipulated



Credential/session risk

### 6. Wireless Reconnaissance

Check the wireless adapter:

```
iwconfig
```

Enable monitor mode:

```
sudo airmon-ng start wlan0
```

Scan the authorized environment:

```
sudo airodump-ng wlan0mon
```

Record:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength

## 7. Identify Duplicate SSIDs

A suspicious situation may occur when the same SSID appears with unexpected BSSIDs.

For detailed information:

```
sudo iw dev wlan0mon scan
```

Compare:

SSID

BSSID

Channel

Signal

Encryption

## 8. Packet Analysis

Open Wireshark: `sudo`

`wireshark`

Useful wireless filters include:

`wlan.fc.type == 0` and

beacon frames:

`wlan.fc.type_subtype == 0x08`

These can help identify access-point advertisements and management activity.

## 9. Network Analysis

For an authorized lab system:

```
nmap -sV <LAB-IP>
```

This identifies exposed services that may become reachable after wireless access.

## 10. Weaknesses

### WPA2-PSK

A shared password can create authentication and credential-management weaknesses, particularly if the password is weak or reused.

### No Rogue-AP Detection

Without wireless monitoring, unauthorized access points may remain undetected.

### User Trust

Employees may connect to an SSID based only on its name.

### Insufficient Certificate Validation

Users who ignore certificate warnings may expose credentials or sensitive information.

## 11. Risk Assessment

| Vulnerability              | Severity |
|----------------------------|----------|
| Rogue AP                   | Critical |
| Shared weak PSK            | High     |
| Lack of monitoring         | High     |
| Poor certificate awareness | High     |
| User awareness             | Medium   |

## 12. Countermeasures

### Authentication

Replace shared WPA2-PSK with: **WPA2-Enterprise**  
**or WPA3-Enterprise**

Use:

- 802.1X
- RADIUS
- Strong EAP authentication
- Device/user identity

### Wireless Monitoring Deploy:

- Wireless IDS
- Wireless IPS
- Rogue-AP detection
- Centralized logging

### Network Segmentation

Separate:

Employee Wi-Fi

Guest Wi-Fi

IoT

Servers

Management Network

### User Awareness

Employees should:

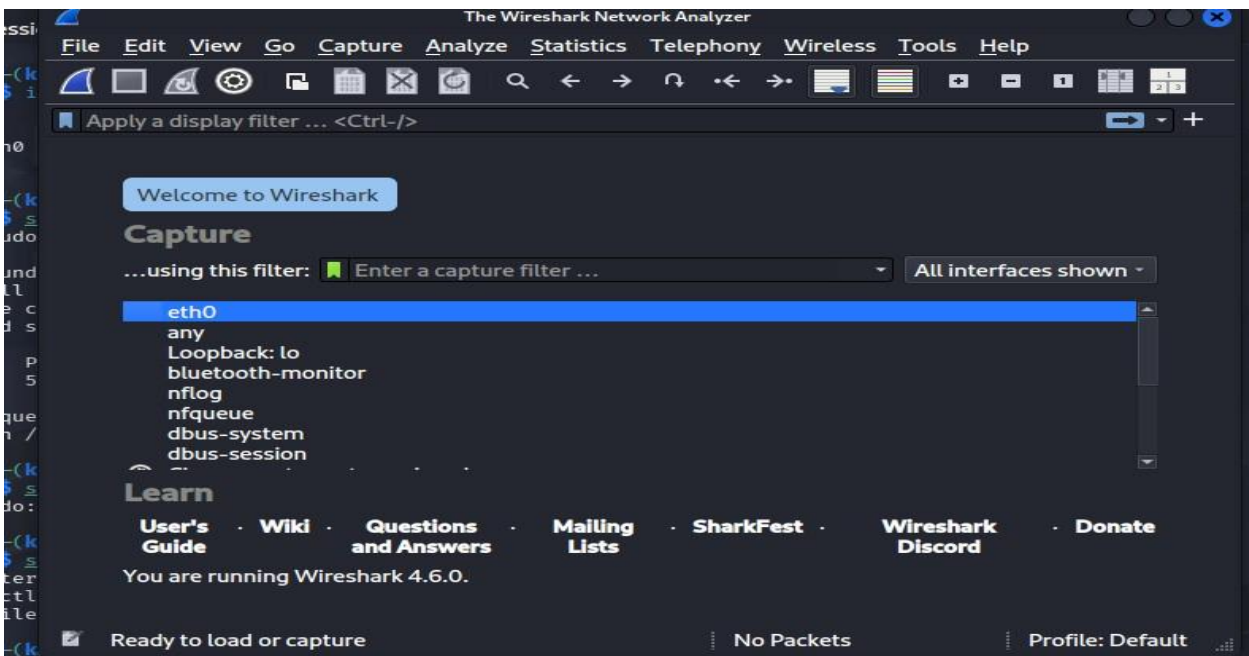
- Verify official SSIDs.
- Never ignore certificate warnings.
- Report unexpected login pages.
- Avoid unknown Wi-Fi networks.
- Use approved VPN solutions where required.

## 13. Conclusion

The Evil-Twin attack demonstrates that SSID authentication alone does not prove that a wireless network is legitimate. WPA2/WPA3-Enterprise, 802.1X authentication, certificate validation, rogue-AP monitoring, segmentation, and employee awareness provide stronger protection than a shared WPA2-PSK configuration.

```
l-$ iwconfig
lo      no wireless extensions.
eth0    no wireless extensions.

(kali@kali)-[~]
$ sudo airmon-ng start wlan0
[sudo] password for kali:
Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill'. Before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode
PID Name
503 NetworkManager
Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
(kali@kali)-[~]
$ sudo airdump-ng wlan0mon
sudo: airdump-ng: command not found
(kali@kali)-[~]
$ sudo airodump-ng wlan0mon
Interface wlan0mon:
ioctl(SIOCGIFINDEX) failed: No such device
Failed initializing wireless card(s): wlan0mon
(kali@kali)-[~]
$ sudo iw dev wlan0mon scan
command failed: No such device (-19)
(kali@kali)-[~]
$ sudo iw dev wlan0mon scan
command failed: No such device (-19)
(kali@kali)-[~]
$ sudo wireshark
(kali@kali)-[~]
$ sudo airmon-ng stop wlan0mon
Requested device "wlan0mon" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
```



## 4. PENETRATION TESTING REPORT

### 1. Title

Assessment of an Internal Employee Management System Exposed Through Wi-Fi

## 2. Objective

To assess the complete attack surface from wireless network access to web application vulnerabilities and privilege escalation, and to develop a defense-in-depth security framework.

## 3. Scenario

An organization's employee management system is accessible through Wi-Fi. The wireless network uses weak passwords, while the web application has weaknesses in authentication and session management.

The assessment evaluates:

- Wireless security
- Network reconnaissance
- Service enumeration
- Web application security
- Authentication
- Session management
- Authorization

## 4. Attack Chain

Weak Wi-Fi



Network Access



Host Discovery



Port Scanning



Web Enumeration



Authentication Testing



Session Testing



Authorization Testing



Privilege Escalation



Sensitive Data Exposure

## 5. Tools Used

- Aircrack-ng
- Airodump-ng
- Nmap
- Gobuster
- Nikto
- Burp Suite
- Wireshark

## 6. Phase 1 — Wireless Assessment

Check the adapter:

`iwconfig` Enable monitor mode:

`sudo airmon-ng start wlan0` Scan

the authorized lab: `sudo`

`airodump-ng wlan0mon` Stop

monitor mode when finished:

`sudo airmon-ng stop wlan0mon`

## 7. Phase 2 — Network Reconnaissance

Identify your IP:

`ip addr`

Identify the network:

`ip route`

Discover authorized hosts:

`sudo nmap -sn <LAB-NETWORK>/24`

## 8. Phase 3 — Port Scanning

Scan the authorized target: sudo

nmap -sV <LAB-IP> Identify

common web services: sudo

nmap -p 80,443 <LAB-IP>

## 9. Phase 4 — Web Enumeration

Identify web technology: whatweb

http://<LAB-IP> Perform web-

server assessment:

nikto -h http://<LAB-IP>

Directory enumeration:

gobuster dir -u http://<LAB-IP> -w /usr/share/wordlists/dirb/common.txt

## 10. Phase 5 — Web Application Testing

Start Burp Suite:

burpsuite

Test the authorized application for:

- Login weaknesses
- Session-management problems
- Access-control issues
- Input-validation problems
- Insecure direct object references
- Missing authorization checks

## 11. Phase 6 — Authentication Testing

Assess:

- Password complexity
- Account lockout

- MFA
- Session expiration
- Logout functionality
- Password reset mechanisms

Do not perform password attacks against real accounts.

## 12. Phase 7 — Session Management

Inspect cookies in Burp Suite.

Check whether session cookies have appropriate:

Secure  
HttpOnly SameSite

attributes.

Assess whether session identifiers change after login and whether logout properly invalidates sessions.

## 13. Phase 8 — Authorization Testing

Using two authorized test accounts, verify that one user cannot access another user's resources.

For example, compare authorized application requests in Burp Repeater using test accounts with different privileges.

The objective is to verify authorization controls rather than access real employee information.

## 14. Risk Assessment

| Vulnerability           | Severity |
|-------------------------|----------|
| Weak Wi-Fi password     | High     |
| Weak authentication     | High     |
| Poor session management | High     |
| Authorization weakness  | Critical |
| Sensitive data exposure | Critical |
| Missing segmentation    | High     |

## **15. Defense-in-Depth Framework**

### **Wireless Layer**

- WPA3-Enterprise
- 802.1X
- Strong authentication
- Rogue-AP detection

### **Network Layer**

- VLAN segmentation
- Firewalls
- IDS/IPS
- NAC
- Restricted management access

### **Application Layer**

- Secure authentication
- MFA
- Secure sessions
- Role-based access control
- Input validation
- Output encoding

### **Data Layer**

- Encryption
- Least-privilege database accounts
- Database monitoring
- Regular backups

### **Monitoring Layer**

- Centralized logging
- SIEM
- Alerting
- Incident response

## **16. Conclusion**

The assessment demonstrates how a weak wireless network can become the initial entry point into an internal application environment. Security must therefore be implemented at multiple layers. Strong wireless authentication, segmentation, firewalls, secure web application

development, robust authorization, MFA, session protection, and centralized monitoring provide defense-in-depth.

```
(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 82702sec preferred_lft 82702sec
   inet6 fd17:625c:f037:2:c895:be2a:58f0:bb0e/64 scope global dynamic noprefixroute
       valid_lft 86303sec preferred_lft 14303sec
   inet6 fe80::66cb:297d:718a:d5c7/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ nmap -sV <TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ gobuster dir -u http://<TARGET-IP> -w /usr/share/wordlists/dirb/common.txt
zsh: no such file or directory: TARGET-IP

(kali@kali)-[~]
$ nikto -h http://<TARGET-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ curl -I http://<TARGET-IP>
zsh: parse error near `\\n'
```

## 5. WIRELESS SECURITY ASSESSMENT REPORT

### 1. Title

Assessment of Wi-Fi Deauthentication Attacks and Wireless Denial of Service

### 2. Objective

To identify and analyze repeated wireless deauthentication activity, understand the protocol weakness involved, evaluate its effect on availability, and recommend appropriate prevention and detection mechanisms.

### 3. Scenario

A university campus experiences repeated Wi-Fi disconnections during peak hours. Investigation indicates repeated deauthentication activity affecting wireless clients.

The assessment examines the attack in an isolated laboratory environment.

### 4. Background

IEEE 802.11 networks use management frames for activities such as authentication, association, disassociation, and deauthentication. Historically, some management frames lacked strong cryptographic protection.

An attacker may attempt to abuse this behavior by transmitting forged management frames, causing clients to disconnect from an access point.

## 5. Tools Used

- Kali Linux
- Aircrack-ng
- Airodump-ng
- Wireshark
- Kismet

## 6. Methodology

Wireless Monitoring



Packet Capture



Management-Frame Analysis



Identify Deauthentication Frames



Determine Frequency



Assess Availability Impact



Implement Detection/Mitigation

## 7. Wireless Monitoring

Check the wireless adapter: `iwconfig`

Enable monitor mode:

```
sudo airmon-ng start wlan0
```

Scan the authorized lab:

```
sudo airodump-ng wlan0mon
```

**8.**

## Capture Wireless Traffic

Capture the authorized test AP:

```
sudo airodump-ng --bssid <BSSID> --channel <CHANNEL> -w deauth_lab wlan0mon
```

## 9. Wireshark Analysis

Open the capture:

wireshark deauth\_lab-01.cap Use

the filter:

wlan.fc.type\_subtype == 0x0c This

identifies deauthentication frames.

Examine:

- Source address
- Destination address
- Reason code
- Number of frames
- Time intervals

## 10. Wireless Monitoring with Kismet

```
sudo kismet
```

Kismet can assist with wireless monitoring and identification of suspicious wireless activity.

## 11. Impact Assessment

Repeated deauthentication can cause:

### Availability Impact

Users may repeatedly lose wireless connectivity.

### Productivity Impact

Students and staff may be unable to access:

- Learning platforms
- Email
- Internal systems
- Cloud applications

### Operational Impact

Persistent wireless disruption can interfere with campus operations.

## 12. Risk Assessment

| Risk                      | Severity |
|---------------------------|----------|
| Repeated deauthentication | High     |
| Network availability loss | High     |
| User productivity loss    | High     |
| Service interruption      | High     |

## 13. Countermeasures

### Protected Management Frames

Enable **802.11w Protected Management Frames** where supported.

### WPA3

Use WPA3 for modern wireless deployments and enable appropriate PMF settings.

### Wireless IDS/IPS

Deploy systems capable of detecting:

- Excessive deauthentication
- Rogue APs
- Abnormal management frames
- Wireless interference

### Network Configuration

- Keep AP firmware updated.
- Use enterprise authentication.
- Segment wireless networks.
- Maintain redundant AP coverage.
- Monitor channel utilization.

### Incident Response

When repeated deauthentication is detected:

1. Identify affected APs.

2. Analyze management-frame sources.
3. Check for rogue devices.
4. Review wireless-controller logs.
5. Correlate events using centralized monitoring.
6. Physically investigate suspicious devices where appropriate.

## 14. Legal and Ethical Considerations

Intentional wireless disruption can violate organizational policies and applicable laws. Deauthentication testing should therefore be performed only in an isolated laboratory or with explicit authorization.

## 15. Conclusion

Deauthentication attacks can significantly affect wireless availability by forcing legitimate clients to disconnect. Monitoring, Protected Management Frames, WPA3, wireless IDS/IPS, updated infrastructure, and appropriate incident-response procedures can substantially reduce the impact of wireless denial-of-service attacks.

## 16. Evidence

Attach:

- `iwconfig`
- `airmon-ng`
- `airodump-ng`
- Wireshark deauthentication-frame screenshot
- Kismet monitoring screenshot

```

(kali@kali)-[~]
$ sudo airmon-ng start wlan0

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo airmon-ng start wlan0

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo airodump-ng wlan0mon
Interface wlan0mon:
ioctl(SIOCGIFINDEX) failed: No such device
Failed initializing wireless card(s): wlan0mon

(kali@kali)-[~]
$ sudo airodump-ng --bssid <BSSID> --channel <CHANNEL> -w deauth wlan0mon
zsh: no such file or directory: BSSID

(kali@kali)-[~]
$ wireshark deauth-01.cap

(kali@kali)-[~]
$ sudo airmon-ng stop wlan0mon

Requested device "wlan0mon" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

```

